

**UNIMINUTO VIRTUAL**

**PRESENTADO POR:**

**TORRES ORTEGA CARLOS STEVEN**

**ENTREGADO A:**

**CESAR ALFONSO BOLADO SILVA**

**NCR: 93980**

**PUERTO SALGAR CUNDINAMARCA**

**23 DE JULIO DEL 2026**

## Contenido

|                                                                |   |
|----------------------------------------------------------------|---|
| Identificación y justificación de hallazgos de seguridad ..... | 3 |
| Matriz verificación y validación.....                          | 3 |
| Lista de verificación de revisión técnica.....                 | 4 |
| Plan de auditoria .....                                        | 4 |
| Datos generales.....                                           | 4 |
| Hallazgos .....                                                | 5 |
| Conclusión general .....                                       | 5 |
| Aplicación del estándar ISO/IEC 25010 .....                    | 5 |
| Métricas de calidad .....                                      | 6 |
| Conclusiones y recomendaciones .....                           | 6 |
| Conclusiones: .....                                            | 6 |
| Recomendaciones .....                                          | 6 |
| Bibliografía .....                                             | 6 |

## Identificación y justificación de hallazgos de seguridad

| N° | Hallazgo de seguridad                               | Evidencia | impacto                                                     | Acción recomendada                                   |
|----|-----------------------------------------------------|-----------|-------------------------------------------------------------|------------------------------------------------------|
| 1  | Acceso no autorizado a historias clínicas           | INC-101   | Acceso indebido a la información clínica                    | Implementar control de acceso por roles              |
| 2  | Uso compartido de cuentas administrativas           | INC-102   | Perdida de trazabilidad y riesgos de accesos no autorizados | Asignar cuentas individuales y cambio de contraseñas |
| 3  | Canal de telemedicina sin cifrado                   | INC-103   | Exposición de información sensible                          | Configurar cifrado obligatorio                       |
| 4  | Exposición de datos de tarjetas de pago             | INC-104   | Riesgos de fraude                                           | Enmascarar la información de las tarjetas            |
| 5  | Falta de registro de consultas a historias clínicas | INC-105   | Falta de trazabilidad de los accesos                        | Registrar consultas y modificaciones                 |

## Matriz verificación y validación

| ID           | Requisito/ funcionalidad relacionada       | Tipo (V/V)   | Técnica a aplicar      | Responsable         | Criterios de aceptación    | Evidencia esperada     |
|--------------|--------------------------------------------|--------------|------------------------|---------------------|----------------------------|------------------------|
| RF-022       | Cifrado de historia clínica                | verificación | Revisión configuración | Administrador       | Datos cifrados             | Informe de revisión    |
| RF-031       | Rendimiento en módulo de agendamiento      | validación   | Prueba de carga        | Equipo de pruebas   | Respuesta < a 2s           | Reporte de pruebas     |
| RF-045       | Registro de acceso a historias clínicas    | verificación | Revisión logs          | Líder técnico       | Accesos registrados        | Registro de auditoria  |
| RF-052       | Cumplimiento PCI-DSS                       | verificación | Auditoria de seguridad | auditor             | Sin datos en las tarjetas  | Informe de auditoria   |
| RF-060       | Cifrado canal de telemedicina              | verificación | Revisión configuración | Administrador TI    | Canal cifrado              | reporte configuración  |
| CR-201       | Funcionamiento inciso de sesión            | validación   | Prueba aceptación      | Product owner       | Correcto inicio de sesión  | Acta de pruebas        |
| INC-101      | Control de acceso por roles                | verificación | Prueba seguridad       | Equipo de seguridad | Sin accesos no autorizados | Informe de pruebas     |
| INC-106      | Integración con AS/400                     | validación   | Prueba integración     | Administrador TI    | No fallos de integración   | Reporte integración    |
| Telemedicina | Experiencia de usuario en videoconferencia | validación   | Prueba piloto          | Product owner       | videollamada               | Encuestas satisfacción |

## Lista de verificación de revisión técnica

| N° | Ítem de revisión                                         | cumple    | observaciones                                          |
|----|----------------------------------------------------------|-----------|--------------------------------------------------------|
| 1  | Código cumple con estándares definidos                   | N/A       | Evidencia insuficiente del caso                        |
| 2  | Trazabilidad existente entre requisitos y pruebas        | no        | Algunos requisitos no aprobados                        |
| 3  | Los cambios fueron revisados y aprobados                 | no        | Cambios sin aprobación registrada                      |
| 4  | Protección de recursos críticos                          | no        | Acceso no autorizado a historias clínicas              |
| 5  | Información sensible está cifrada                        | no        | El canal de telemedicina presenta fallos en el cifrado |
| 6  | Registro de accesos a información                        | no        | No se evidencia consultas                              |
| 7  | Ejecución de pruebas de seguridad antes de la liberación | no        | El pentesting no fue realizado                         |
| 8  | Sistema cumple con PCI-DSS                               | pendiente | Auditoria aun no ejecutada                             |
| 9  | Pruebas para verificar rendimiento del sistema           | no        | Prueba de carga pendiente                              |
| 10 | documentación actualizada                                | si        | Documentación y requisitos disponibles                 |

## Plan de auditoria

### Datos generales

| Campo                    | Contenido                                                                                   |
|--------------------------|---------------------------------------------------------------------------------------------|
| Objetivo de la auditoria | Evaluar requisitos de calidad, seguridad y normatividad del sistema MediCitas               |
| Alcance                  | Historia clínica, telemedicina, pagos y facturación                                         |
| Criterios de auditoria   | ISO/IEC 25010, ley 1581 del 2012, resolución 1995 de 1999, PCI-DSS                          |
| Equipo auditor           | Auditor líder, oficial de protección de datos y especialista en seguridad de la información |
| Fecha de ejecución       | Tres semanas antes de la liberación del sistema                                             |
| Evidencias a recolectar  | Resultados de pruebas de registro de acceso y configuración del sistema                     |

## Hallazgos

| N° | hallazgo                                         | Criterio incumplido | Evidencia      | severidad  | recomendación                    |
|----|--------------------------------------------------|---------------------|----------------|------------|----------------------------------|
| 1  | Acceso no autorizado a historias clínicas        | ISO/IEC 25010       | INC-101        | alta       | Acceso por roles                 |
| 2  | Cuentas administrativas compartidas              | ISO/IEC 25010       | INC-102        | alta       | Asignar cuentas individuales     |
| 3  | Canal de telemedicina sin cifrado                | RF-060              | INC103/ CR-202 | alta       | Implementar cifrado              |
| 4  | Exposición de datos de tarjetas                  | PCI-DSS             | INC-104        | alta       | Enmascarar datos de las tarjetas |
| 5  | Falta de registro de accesos en historia clínica | RF-045              | INC105         | Media-alta | Registrar accesos de lectura     |

## Conclusión general

En la auditoría realizada a MediCitas, se identifican hallazgos que afectan la seguridad de la información, control de acceso, protección de datos y el cumplimiento de la normativa. Esto evidencia que el sistema presenta riesgos los cuales deben ser corregidos antes de la liberación. Por lo tanto, se recomienda realizar acciones correctivas, ejecutar pruebas pendientes y verificar nuevamente los requisitos funcionales, no funcionales y regulatorios con el fin de garantizar el servicio seguro.

| auditor                     | fecha      |
|-----------------------------|------------|
| Torres Ortega Carlos Steven | 24-07-2026 |

## Aplicación del estándar ISO/IEC 25010

| ISO/IEC 25010                   | Aplicación al caso MediCitas                                                                               |
|---------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>Seguridad</b>                | Protección de las historias clínicas, datos personales e información de pagos mediante controles de acceso |
| <b>Confiabilidad</b>            | Garantizar el funcionamiento continuo del sistema y reducir fallos como facturación                        |
| <b>Eficiencia del desempeño</b> | Verificar que el módulo de agendamiento responda en menos de 2 segundos                                    |

|                       |                                                                                 |
|-----------------------|---------------------------------------------------------------------------------|
| <b>Compatibilidad</b> | Asegurar la correcta integración con el sistema AS/400 y los servicios externos |
| <b>mantenibilidad</b> | Facilitar corrección de errores y la implementación de mejoras                  |

## Métricas de calidad

| métrica                              | Forma de medición                                                  | Criterio de aceptación                 |
|--------------------------------------|--------------------------------------------------------------------|----------------------------------------|
| <b>Densidad hallazgos críticos</b>   | Numero de hallazgos críticos                                       | No deben existir hallazgos críticos    |
| <b>Cobertura de pruebas</b>          | Pruebas criticas ejecutadas                                        | Las pruebas deben estar ejecutadas     |
| <b>Tasa de cambios sin revisión</b>  | Comprobar que los cambios sean revisados                           | Cambios aprobados antes del despliegue |
| <b>Fallos de procesos sin alerta</b> | Revisar los fallos del sistema                                     | Los fallos deben generar alertas       |
| <b>Disponibilidad del sistema</b>    | Verificar que el sistema este disponible en el horario de atención | Disponibilidad al 99.5%                |

## Conclusiones y recomendaciones

### Conclusiones:

- La aplicación de verificación y validación permitieron identificar fallas de calidad, seguridad y cumplimiento.
- La ISO/IEC 25010 facilito evaluar la seguridad, confiabilidad y desempeño permitiendo identificar los aspectos que deben fortalecerse
- Las métricas definidas nos permiten hacer un seguimiento al software y apoyar la toma de decisiones con pro de este.

### Recomendaciones

- corregir hallazgos antes de la liberación del sistema
- Ejecutar pruebas de seguridad y rendimiento pendientes para verificar el cumplimiento de requisitos
- Fortalecer controles de acceso, registro de auditoria para garantizar mayor seguridad y confiabilidad

## Bibliografía

Chavarría, A., Oré, S., & Pastor, C. (2016). *Aseguramiento de la calidad en el proceso de desarrollo de software utilizando CMMI, TSP y PSP*. Revista Ibérica de Sistemas e Tecnologias de Informação, (20), 62–77)

Paredes, L., Benavides, L., & Sánchez, N. (2017). *Guía de recomendación para la selección de un modelo de calidad para la mejora de procesos de software (SPI)*. Revista Ciencias Estratégicas.